

Vanteloq Information Security Policy

DRAFT FOR APPROVAL

Owner signature is required before this policy is represented as adopted or uploaded to Plaid.

Document control	Value
Organization	LexEdge Consulting, operating Vanteloq
Policy owner	Hussien Issa, Owner and Security Lead
Version	1.0
Prepared	2026-08-13
Review cycle	Quarterly control review; full annual review
Approval status	Awaiting owner approval

1. Purpose and scope

This policy establishes the minimum safeguards for Vanteloq systems and information. It applies to the production application, source code, Cloudflare services, Supabase authentication and data services, connected financial and commerce providers including Plaid, administrative accounts, employee and contractor endpoints used for production access, and every person with access to those systems.

The policy is designed to protect confidentiality, integrity, availability, privacy, and tenant separation. It is a control standard and operating requirement, not a representation that every planned control has already produced historical evidence.

2. Security governance and risk management

The Owner and Security Lead is accountable for the security program, risk decisions, policy approval, incident coordination, vendor review, and evidence retention. Vanteloq will:

- maintain a risk register covering threats, affected assets, likelihood, impact, owner, treatment, due date, and residual risk;
- review material risks and open exceptions at least quarterly and after major architecture changes, incidents, or new sensitive-data integrations;
- record policy approvals, control reviews, exceptions, incidents, and corrective actions;
- perform an annual policy review and document any changes; and
- require written approval, compensating controls, an expiry date, and a named owner for every exception.

Security concerns are reported to the policy owner. A monitored `security@vanteloq.com` address may be listed publicly only after the mailbox or forwarding rule has been created and tested.

3. Data classification and handling

Vanteloq classifies information as:

- 1 **Restricted** — credentials, authentication secrets, Plaid access tokens, financial account data, private customer data, and security evidence that exposes sensitive configuration.
- 2 **Confidential** — tenant business records, invoices, receipts, employee records, internal reports, source code, and non-public operating data.
- 3 **Internal** — procedures, architecture documentation, and non-public business information without restricted data.
- 4 **Public** — approved website, product, legal, and support content.

Restricted data must use approved encrypted storage and encrypted transport, remain server-side unless a product function explicitly requires otherwise, and be available only to the minimum authorized role. Restricted credentials must never be committed to source control, included in client bundles, placed in logs, or shared through unapproved channels.

4. Identity, access, and authentication

Production and administrative access requires unique identities. Shared accounts are prohibited unless a provider technically requires one and the exception is documented. Access must follow least privilege and role-based access control.

For Vanteloq users, Supabase is the authoritative identity provider. The application verifies signed bearer tokens on the server, binds the immutable user subject to an active organization membership, enforces role and permission checks, and requires AAL2 for protected application and integration actions. Vanteloq's current AAL2 factor is TOTP, which is multi-factor authentication but is not phishing-resistant.

Administrative accounts for Cloudflare, Supabase, Plaid, source control, email, and other critical systems must use MFA where the provider supports it. Access must be reviewed quarterly. Access for a terminated worker must be disabled no later than one business day after termination, and immediately for an involuntary or security-related termination. Transferred workers must have access adjusted within one business day.

Service-to-service access must use scoped OAuth tokens, short-lived credentials, signed requests, or TLS-protected API credentials. Secrets must be stored in provider-managed production environment variables and rotated after exposure, administrator departure, or provider security notification.

5. Encryption and key management

Vanteloq requires TLS 1.2 or later for external production traffic. HSTS and secure response headers must remain enabled. The production edge is not eligible for a compliant declaration while an independent TLS 1.1 handshake succeeds; this is an open exception that must be remediated before answering Plaid's TLS question affirmatively.

Cloudflare D1 encrypts stored database objects at rest. Plaid credentials stored by Vanteloq also receive application-level AES-256-GCM encryption with random nonces and authenticated context. Encryption keys and provider secrets remain server-side and separate from encrypted values.

Key access is restricted to production workloads and authorized administrators. Keys are rotated following suspected compromise, privilege changes, or provider requirements. Sensitive values are redacted from logs and error responses.

6. Secure development and change management

Security requirements are part of design, implementation, review, testing, and release. Production changes must:

- validate and normalize untrusted input;
- enforce authentication, tenant, role, location, and data-ownership checks on the server;
- fail closed when identity, consent, or authorization evidence is missing;
- use bounded request bodies, allowlisted values, parameterized storage access, and safe structured errors;
- preserve audit records for sensitive actions;
- pass relevant type, lint, unit, boundary, and security tests; and
- avoid fabricated analytics when source data is incomplete or stale.

Production secrets are not stored in the repository. Dependencies are locked and reviewed before release. Sensitive integration workflows require state binding, current consent, idempotency, rate limiting, and server-side credential exchange.

7. Vulnerability management

Vanteloq monitors application dependencies and runtime support status. Findings are prioritized by exploitability, data sensitivity, tenant exposure, and operational impact. From the date this policy is approved, the remediation targets are:

Severity	Target
Critical, known exploited, or active credential exposure	contain immediately; remediate within 24 hours
High	remediate within 7 calendar days
Medium	remediate within 30 calendar days
Low	remediate within 90 calendar days or document acceptance

Exceptions require written risk acceptance and an expiry date. Internet-facing application scans, dependency reviews, and end-of-life checks must be documented. Endpoint vulnerability scanning for every employee and contractor device is not claimed until a managed device-scanning program is deployed and evidenced.

8. Logging, monitoring, and incident response

Security-relevant events must be recorded with timestamp, actor or service, organization, action, result, and correlation identifier when available. Logs must not contain passwords, session tokens, Plaid access tokens, encryption keys, or full sensitive payloads.

Suspected unauthorized access, disclosure, data loss, malware, provider compromise, or tenant-boundary failure activates the incident response process. The Security Lead will triage severity, contain access, preserve evidence, rotate credentials, assess affected data and parties, recover safely, and document lessons learned. Notifications to consumers, providers, regulators, or law enforcement will be made when contract or applicable law requires them.

9. Availability, recovery, and continuity

Production data recovery must rely on provider-supported backups, replication, or export procedures. Restoration procedures and critical integration failure modes must be tested at least annually. A backup or recovery capability cannot be represented as verified until a dated restore test has succeeded and evidence has been retained.

10. Privacy, retention, and consumer rights

Vanteloq collects only data needed for disclosed business functions, obtains affirmative consent before initiating Plaid Link, records the consent version and purpose, and provides a deletion workflow for connected financial data. The public privacy notice must identify the categories collected, purposes, providers, transfers, retention approach, rights, contact channel, and effective date.

Retention and deletion are governed by the separate Vanteloq Data Retention and Disposal Policy. Legal holds suspend only the affected deletion and must be documented. Plaid access must be disconnected when no longer required or when the consumer withdraws authorization.

11. Third-party and provider security

Before a provider processes restricted data, Vanteloq will review the service purpose, data shared, authentication model, encryption, retention, deletion, incident notification, geographic processing, and termination process. Provider permissions must be limited to the functions enabled by the consumer. Material changes trigger a new review.

12. Training and enforcement

People with production access must review this policy at onboarding and annually, complete security and privacy training appropriate to their role, report suspected incidents promptly, and acknowledge their confidentiality and acceptable-use duties. Violations may result in access removal, disciplinary action, contract termination, and legal escalation.

13. Evidence and review

The following records support this policy: access reviews, MFA status checks, dependency and vulnerability results, test reports, release evidence, incident records, provider reviews, restore tests, policy approvals, retention jobs, and deletion audit events. Evidence must be dated, attributable, and protected from unauthorized changes.

This policy takes effect only when the owner completes the approval record. The first quarterly control review is due within 90 days of approval.

Approval

Field	Entry
Approved by	
Title	Owner and Security Lead
Approval date	
Signature	
Next annual review	